Systems Privacy — Project 1 · Ano letivo 2026/2027

Número do aluno: 77481

1. Introdução e objetivos

A plataforma DataSafe simula a gestão de informação num ambiente hospitalar. A aplicação trabalha com dados de pacientes, funcionários, consultas, pagamentos, consentimentos e medições clínicas. A existência de relações entre estes registos facilita operações do dia a dia, mas também aumenta o impacto de um acesso indevido ou de uma divulgação de dados.

O problema não se resolve apenas retirando nomes de uma tabela. Uma combinação de idade, código postal e data de diagnóstico pode permitir reconhecer um paciente, sobretudo quando existe informação externa disponível. Por outro lado, limitar todos os acessos indiscriminadamente retiraria utilidade aos dados, incluindo para investigação. O trabalho procura, por isso, equilibrar duas necessidades: permitir tratamentos legítimos e reduzir o risco de exposição individual.

De acordo com o enunciado do Project 1 [1], o DataSafe integra quatro componentes: controlo de acesso com Contextual Integrity e XACML; mecanismos associados ao RGPD; anonimização através de Mondrian, k-anonymity e t-closeness; e consultas agregadas com privacidade diferencial. Estas técnicas não são equivalentes: cada uma atua numa fase diferente do tratamento e responde a ameaças distintas.

O relatório apresenta a arquitetura e os resultados observados em dois ensaios distintos: regressão idade–glicose com 150 pacientes e consultas agregadas de privacidade diferencial numa base de teste com cinco registos. A separação evita confundir métricas de regressão com erros de médias ruidosas.

1.1. Critério de avaliação

A regressão é avaliada por R^2 e erro quadrático médio (MSE), calculados sobre pares idade–glicose. As médias com ruído são avaliadas por erro absoluto médio (MAE) e MSE face à média real. Estas métricas de avaliação foram calculadas com acesso aos dados originais e não constituem, por si mesmas, saídas privadas.

2. Arquitetura e modelo de ameaças

O projeto está desenvolvido em Java, recorrendo ao Hibernate para a persistência de entidades numa base SQLite (privsys.db). A classe DataSafe.java concentra a interação com o utilizador e os fluxos funcionais; XACMLPDP.java centraliza decisões de autorização; KAnonymityTool.java processa os microdados; e DifferentialPrivacyTool.java suporta consultas estatísticas. Esta divisão torna mais fácil identificar a responsabilidade de cada módulo e testar alterações sem misturar lógica de acesso com cálculo estatístico.

O modelo de dados inclui Patient, Employee, Appointment, Payment, ConsentRecord, GDPRRequest e HealthData, entre outras entidades. A ligação entre tabelas é útil para o funcionamento da aplicação, mas significa que uma exportação ou consulta não pode ignorar as relações existentes. A proteção tem de ser aplicada tanto aos atributos individuais como às operações que permitem navegar entre entidades.

2.1. Ameaças consideradas

A primeira ameaça é um utilizador interno com credenciais válidas que tenta aceder a dados fora da finalidade autorizada. Por exemplo, um funcionário da faturação não necessita de consultar todas as medições clínicas de um paciente. O controlo contextual procura distinguir a autenticação de uma autorização efetiva para cada operação.

A segunda ameaça corresponde a ataques de cruzamento de informação (linkage attacks). Mesmo sem identificadores diretos, conjuntos de quasi-identificadores podem ser associados a fontes externas. A generalização aplicada pelo Mondrian reduz a granularidade desses atributos e procura criar grupos de registos indistinguíveis nos campos publicados.

A terceira ameaça é a inferência através de consultas repetidas. Um analista pode comparar respostas de subconjuntos semelhantes e tentar inferir a contribuição de um indivíduo. A privacidade diferencial limita o efeito de adicionar ou retirar um registo e o orçamento ε impede a execução ilimitada de consultas com custo acumulado.

2.2. Fronteiras da proteção

Os mecanismos anteriores não substituem cifragem da base de dados, proteção do canal de comunicação, gestão segura de credenciais ou auditoria de alterações ao código. Também não garantem anonimato quando um atacante já possui a tabela original. O relatório avalia sobretudo as garantias de autorização e privacidade previstas no projeto académico, não uma solução hospitalar pronta para produção.

3. Controlo de acessos e Contextual Integrity

A teoria de Contextual Integrity, apresentada por Nissenbaum [2], entende a privacidade como respeito pelas normas que regulam a circulação de informação num contexto. Para um fluxo ser adequado, não basta saber quem o pediu: interessa quem é o titular, quem envia e recebe a informação, qual o tipo de dado e sob que princípio ocorre a transmissão.

No DataSafe, estes elementos são traduzidos em atributos avaliados pelo XACML. A biblioteca AuthzForce desempenha o papel de Policy Decision Point (PDP). Em cada pedido, a aplicação apresenta atributos do sujeito, recurso, ação e contexto, incluindo a base legal quando relevante. A decisão devolvida pelo motor é utilizada para autorizar ou impedir a operação.

3.1. Regras e combinação de políticas

O ficheiro ci_policy.xml funciona como ponto de integração das regras. O enunciado admite políticas separadas, combinadas através de um PolicySet, e esclarece a utilização do algoritmo deny-overrides [1]. Nesta configuração, uma decisão de negação aplicável prevalece sobre uma permissão concorrente. O objetivo é evitar que uma regra genérica de acesso anule uma restrição mais específica.

A assinatura de checkAccess deve incluir a ação solicitada e a base legal. Esta alteração é especialmente relevante na exportação de dados, para a qual o enunciado indica legal-obligation como fundamento. O mesmo utilizador pode receber decisões diferentes consoante pretenda ler, alterar ou exportar um recurso.

O enunciado também prevê regras para os perfis DPO e Auditor. Estes perfis necessitam de acesso amplo para cumprir funções de supervisão, mas essa exceção deve estar explicitamente representada na política, em vez de depender de verificações dispersas no código. Num sistema real, tal acesso exigiria registo e revisão periódica.

3.2. Validação funcional

A validação das políticas de controlo de acesso é realizada através da classe PolicyTest.java, que contempla cenários de autorização (Permit) e rejeição (Deny). Estes testes permitem verificar o comportamento das políticas XACML perante diferentes pedidos de acesso. A avaliação funcional deve considerar os atributos associados ao utilizador, ao recurso, à ação e ao contexto da operação, de modo a verificar se as decisões produzidas correspondem às regras de autorização definidas. A cobertura dos testes fica limitada aos cenários efetivamente executados, não sendo possível garantir a validação de todas as combinações de atributos e condições.

4. RGPD: consentimento, retenção e direitos dos titulares

A conformidade com o Regulamento Geral sobre a Proteção de Dados exige mais do que impedir acessos não autorizados. É necessário conhecer a finalidade do tratamento, a base de licitude, o período de conservação e os direitos aplicáveis a cada titular. No projeto, estes aspetos são representados por registos de consentimento e pedidos RGPD, associados às entidades da aplicação.

4.1. Consentimento e conservação

A entidade ConsentRecord permite registar o titular, a finalidade, a concessão ou retirada do consentimento e as datas correspondentes. Se o tratamento depende do consentimento, a sua retirada deve impedir novas operações com esse fundamento. No entanto, a retirada não elimina automaticamente todas as obrigações legais de conservação: determinados registos financeiros podem ter de permanecer acessíveis a pessoas autorizadas.

Esta separação entre consentimento e outras bases de licitude evita uma interpretação simplista do RGPD. Um dado pode deixar de ser utilizado para uma finalidade e continuar a ser conservado para outra, desde que exista fundamento adequado e sejam respeitados os limites aplicáveis.

4.2. Apagamento e exportação

O tratamento dos pedidos de apagamento de dados pessoais é realizado através de um mecanismo de apagamento lógico na entidade `Patient`, que substitui os identificadores pessoais por um token no formato `ANON-uuid`, preservando as relações necessárias à integridade referencial da base de dados. Esta abordagem permite reduzir a exposição de informação diretamente identificável sem comprometer a consistência dos registos associados. Contudo, a substituição de identificadores não garante, por si só, uma anonimização irreversível, podendo constituir uma forma de pseudonimização caso subsistam elementos que permitam a reidentificação do titular.

Relativamente ao direito de acesso e à portabilidade dos dados, o DataSafe contempla mecanismos de exportação de informação pessoal. A visibilidade das relações associadas aos registos deve ser determinada pelas decisões do Policy Decision Point (PDP), de acordo com as políticas XACML aplicáveis, em vez de depender exclusivamente de condições fixas associadas ao tipo de utilizador. Deste modo, a informação disponibilizada pode variar consoante os atributos do pedido, o recurso solicitado e as permissões atribuídas. O processo deve ainda contemplar os pedidos RGPD e os registos de consentimento associados ao titular.

A validação funcional destes mecanismos inclui a verificação das operações de apagamento lógico e exportação de dados. A avaliação deve confirmar a preservação da integridade referencial após o apagamento, a aplicação das decisões do PDP na seleção das relações exportadas e a consistência dos dados disponibilizados. A existência destes mecanismos no protótipo não implica, por si só, a garantia de anonimização irreversível ou de conformidade integral com o RGPD, sendo

estas propriedades dependentes das condições concretas de implementação e dos resultados da validação.

5. Anonimização: k-anonymity e t-closeness

A publicação de microdados exige distinguir identificadores diretos, quasi-identificadores e atributos sensíveis. Os primeiros, como o nome, são removidos do conjunto divulgado. Os quasi-identificadores, como idade ou código postal, podem ser generalizados. A glicose é tratada como atributo sensível, cuja distribuição deve ser analisada sem a alterar arbitrariamente.

5.1. Particionamento Mondrian

O algoritmo Mondrian divide recursivamente o conjunto de registos segundo dimensões dos quasi-identificadores. Cada partição só deve ser aceite se as restrições de privacidade forem respeitadas. Na k-anonymity, cada combinação publicada de quasi-identificadores tem de corresponder a pelo menos k registos. Assim, um indivíduo não fica isolado apenas pela combinação desses campos.

A generalização tem um custo: ao substituir idades ou códigos postais exatos por intervalos, perde-se detalhe potencialmente útil para análises. O valor de k influencia este compromisso. Um k maior tende a aumentar a proteção contra identificação por quasi-identificadores, mas pode obrigar a intervalos mais amplos e a uma perda superior de informação.

5.2. t-closeness e distância EMD

A k-anonymity garante que cada registo é indistinguível de pelo menos k − 1 outros registos relativamente aos quase-identificadores considerados. Contudo, esta propriedade não impede que os elementos de uma mesma classe de equivalência apresentem valores sensíveis semelhantes, permitindo potenciais inferências sobre os titulares. Para reduzir este risco, a t-closeness estabelece que a distância entre a distribuição do atributo sensível numa classe de equivalência e a respetiva distribuição global não deve ultrapassar um limiar t.

No DataSafe, a avaliação da t-closeness recorre à Earth Mover's Distance (EMD), considerando a distância numérica efetiva entre os valores de glicose. Uma vez que estes valores não apresentam necessariamente intervalos uniformes, o cálculo da distância deve refletir as diferenças reais entre valores consecutivos, sendo o resultado normalizado pela amplitude global do atributo sensível. Esta abordagem permite avaliar a proximidade entre distribuições, tendo em consideração a magnitude das diferenças nos valores de glicose.

Na experiência de regressão, foram utilizados os parâmetros k = 3 e t = 0,2. A aplicação da k-anonymity através do algoritmo Mondrian produziu 33 classes de equivalência, com dimensões entre 3 e 10 registos. A variante que incorpora t-closeness originou 21 classes, com dimensões entre 3 e 20 registos, não tendo sido identificadas violações do limiar t na avaliação realizada. Estes resultados demonstram a satisfação dos critérios configurados no conjunto de dados experimental, embora não eliminem todos os riscos de inferência ou reidentificação.

6. Privacidade diferencial: mecanismo e orçamento

A privacidade diferencial (DP) limita probabilisticamente a influência da presença ou ausência de um indivíduo numa resposta. Na ferramenta de consultas de glicose, cada paciente contribui com

um valor selecionado e limitado a [0,600]. Esta definição de adjacência por paciente deve distinguir-se de mecanismos que operem diretamente sobre linhas individuais.

6.1. Sensibilidade e ruído de Laplace

A implementação utiliza o mecanismo de Laplace com escala b = Δf/ε. Para COUNT, Δf = 1; para SUM, Δf = 600, dado o clipping da glicose em [0,600]. A consulta AVERAGE perturba separadamente a soma e a contagem, atribuindo ε/2 a cada uma, e calcula a razão por pós-processamento com denominador mínimo de 1. O HISTOGRAM perturba cada uma das seis contagens com escala 1/ε; por serem classes mutuamente exclusivas, a sensibilidade L1 do vetor de contagens é 1 no modelo de adição/remoção.

O código utiliza SecureRandom para gerar ruído de Laplace. A consulta verifica o orçamento antes de executar a operação; um custo inválido ou superior ao saldo é rejeitado. O orçamento é consumido antecipadamente e não é automaticamente devolvido se a execução posterior falhar. O estado SUCCESS demonstra a conclusão operacional da chamada, não uma prova isolada da garantia matemática.

Os métodos disponíveis são countBelowGlucose, sumGlucoseValues, averageGlucoseValues e histogramGlucoseValues. Os testes verificam o estado de sucesso, os valores finitos, as seis classes do histograma e o saldo após a consulta. O orçamento é gerido por instância através de PrivacyBudgetManager; não existe evidência, nestes testes, de um contador global que cubra todas as instâncias ou outras vias de acesso aos mesmos dados.

6.2. Composição sequencial e paralela

Na composição sequencial, os custos de consultas sobre dados sobrepostos somam-se. O teste executado inicia ε = 2,0, consome 0,5 numa contagem e 1,0 numa soma, terminando com saldo 0,5. O teste de orçamento insuficiente confirma a rejeição de uma consulta adicional sem descontar o saldo restante.

Na composição paralela, o método split() agrupa registos por patientId e distribui pacientes inteiros por duas partições disjuntas. No teste, A = {1} e B = {2,3,4,5}; cada partição executa uma consulta com ε = 1,0. Para estas duas consultas sobre subconjuntos disjuntos, a composição paralela permite o limite max(1,0;1,0) = 1,0. Esta propriedade não se estende automaticamente a outras instâncias que consultem os mesmos pacientes.

7. Avaliação experimental e resultados

7.1. Regressão idade–glicose

A experiência de regressão usa 150 pacientes e uma observação agregada por paciente. Nos dados originais, obteve-se declive 1,004869, ordenada na origem 85,773998, R^2 = 0,156080 e MSE = 896,150878. Após Mondrian (k = 3), R^2 = 0,156079 e MSE = 896,151798; com t-closeness (t = 0,2), R^2 = 0,155855 e MSE = 896,390080. Estes valores pertencem à experiência de regressão, não aos cinco registos usados nos testes DP.

Cenário	R^2	MSE
Dados originais (150 pacientes)	0,156080	896,150878
Mondrian, k = 3	0,156079	896,151798
Mondrian + t-closeness, t = 0,2	0,155855	896,390080

Regressão DP, ε = 5 (uma execução)	0,112363	942,573326

A regressão privada utiliza cinco estatísticas perturbadas (n, soma das idades centradas, soma da glicose, soma dos quadrados das idades centradas e soma dos produtos), dividindo ε igualmente pelas cinco. Aplica clipping de idade [0,120], glicose [0,600] e regularização Ridge λ = 10000 no pós-processamento. Como a regressão original não usa a mesma regularização, a diferença de utilidade observada incorpora tanto o ruído como esse efeito de modelação.

7.2. Médias com ruído e erro observado

Na execução Maven de 29/10/2026, os testes de consultas DP utilizaram cinco registos, com média real de glicose de 175,00. Para cada ε ∈ {0,1; 0,5; 1,0; 5,0} realizaram-se 100 repetições, registando sucesso/falha e os erros MAE e MSE relativamente à média real. As quatro séries tiveram 100 sucessos e zero falhas. Os resultados encontram-se na tabela seguinte.

ε	Sucessos / 100	MAE	MSE
0,1	100	6101,23	200235713,38
0,5	100	999,67	3188550,98
1,0	100	368,29	384660,67
5,0	100	46,61	3933,92

Os erros observados diminuíram globalmente com o aumento de ε, como seria esperado com menor escala de ruído. Contudo, a amostra tem apenas cinco registos e a divisão de ε entre soma e contagem produz elevada variabilidade, sobretudo quando o denominador ruidoso se aproxima de zero. O resultado de cada execução é aleatório; as métricas não devem ser extrapoladas para outras bases.

7.3. Composição e interpretação dos resultados

A execução de DPTest confirmou oito testes aprovados, sem falhas nem erros (BUILD SUCCESS). Foram verificados: consultas DP, bloqueio por orçamento insuficiente, composição sequencial, divisão e bloqueio do objeto original, disjunção de pacientes, média ruidosa, histograma e avaliação estatística. O teste paralelo mostrou explicitamente A = {1} e B = {2,3,4,5}.

As 100 repetições por ε criam instâncias separadas para estudar a variabilidade estatística. Isso não equivale a 100 orçamentos independentes perante uma divulgação: se os resultados fossem efetivamente publicados, seria necessário contabilizar a composição total. Os valores de referência e as métricas calculadas a partir dos dados originais são utilizados apenas na avaliação interna.

7.4. O que os resultados demonstram

A regressão original e as duas variantes anonimizadas apresentaram R^2 próximos de 0,156, com pequenas diferenças de MSE. A regressão privada foi avaliada separadamente em 100 repetições por ε: os erros e coeficientes extremos aumentaram substancialmente nos valores baixos de ε. As médias com ruído, calculadas sobre cinco registos, mostram também uma relação marcada entre orçamento de privacidade e utilidade.

Os testes confirmam o comportamento funcional e a contabilização local do orçamento nas condições verificadas. A garantia de ε-DP exige adicionalmente as hipóteses de adjacência, sensibilidade, clipping, geração de ruído e composição apropriadas. A seleção de uma contribuição por paciente e a disjunção por patientId são relevantes para esta interpretação; não se demonstrou uma política global para todas as instâncias.

8. Limitações e conclusão

As principais limitações são a pequena dimensão da base de testes DP (cinco registos), a variabilidade das estimativas ruidosas, a ausência de gestão global de orçamento entre instâncias e a comparação de regressão privada com um modelo original sem a mesma regularização Ridge. A avaliação de regressão tem 150 pacientes, mas os resultados não devem ser generalizados a populações clínicas reais. A contabilização das 100 repetições deve ser tratada como experiência interna, não como autorização de divulgação repetida.

Conclui-se que XACML, RGPD, anonimização e privacidade diferencial respondem a riscos distintos e complementares. A implementação passou oito testes funcionais de DP; a composição sequencial e a disjunção das partições foram verificadas em execução. A utilidade da regressão foi preservada de forma próxima nos dois cenários anonimizados, enquanto as saídas privadas evidenciam o compromisso entre ε e erro. A aplicação deve explicitar os limites das garantias e reforçar a gestão global do orçamento antes de um cenário de produção.

Referências bibliográficas

[1] Gallagher, K. (2026). Systems Privacy Project 1: Implementing Data Privacy, versão 1.2. NOVA FCT. Enunciado fornecido na unidade curricular.

[2] Nissenbaum, H. (2010). Privacy in Context: Technology, Policy, and the Integrity of Social Life. Stanford University Press.

[3] Dwork, C., & Roth, A. (2014). The Algorithmic Foundations of Differential Privacy. Foundations and Trends in Theoretical Computer Science, 9(3–4), 211–407.

[4] OASIS. (2013). eXtensible Access Control Markup Language (XACML), Version 3.0.

[5] Regulamento (UE) 2016/679 do Parlamento Europeu e do Conselho, de 27 de abril de 2016 (RGPD).